

PERBAIKAN HASIL PENTEST

Target: mhc.internationalsos.co.id

Framework: Codelgniter 3 (HMVC)

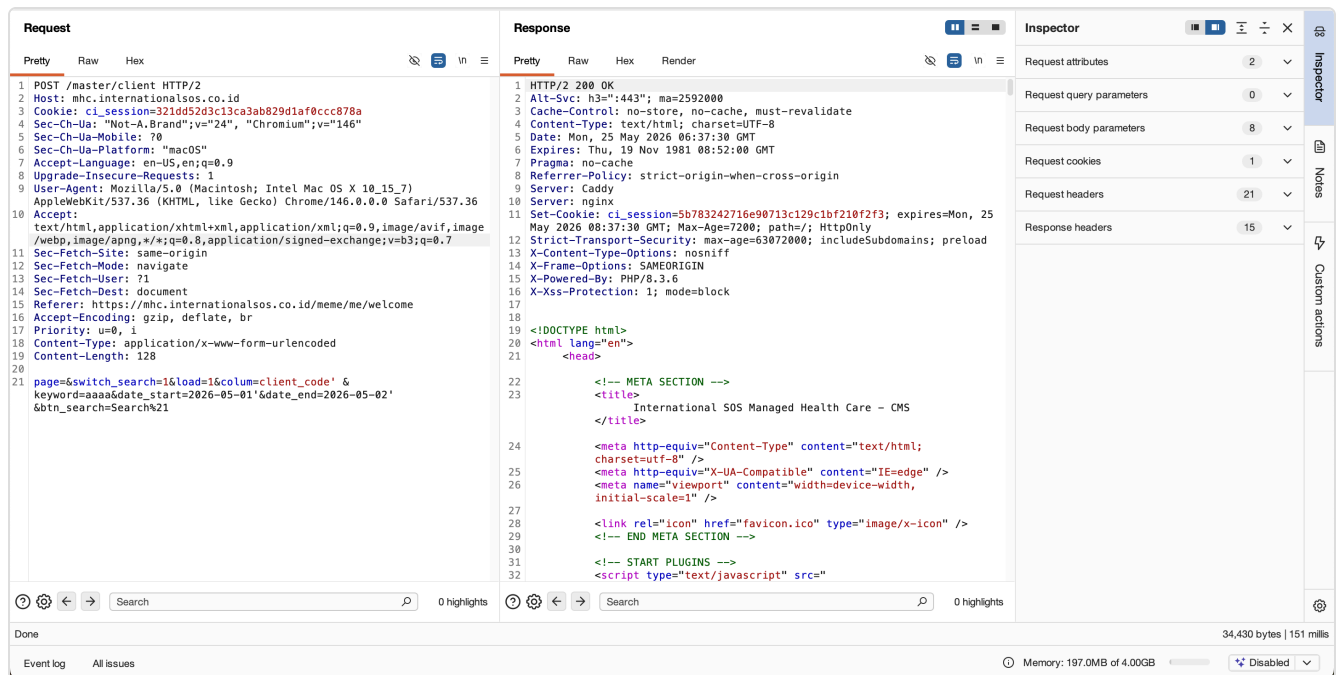
Tanggal Perbaikan: Mei 2026

Sumber Laporan: WebApp_Pentest_Report - mhc_internationalsos_co_id_052026.pdf

A1. SQL Injection — Endpoint Pencarian `/master/client`

Severity: Critical | **CVSS:** 8.8 | **OWASP:** A03:2021 Injection

Hasil testing setelah perbaikan:



The screenshot displays the Chrome DevTools network tab. The selected request is a POST to `/master/client` with a status of 200 OK. The response is an HTML document. The request headers include `Host: mhc.internationalsos.co.id`, `Cookie: cl_session=321dd5203c13ca3ab829d1af0ccc878a`, `Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"`, `Sec-Ch-Ua-Mobile: ?0`, `Sec-Ch-Ua-Platform: "macOS"`, `Accept-Language: en-US,en;q=0.9`, `Upgrade-Insecure-Requests: 1`, `User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36`, `Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7`, `Sec-Fetch-Site: same-origin`, `Sec-Fetch-Mode: navigate`, `Sec-Fetch-User: ?1`, `Sec-Fetch-Dest: document`, `Referer: https://mhc.internationalsos.co.id/meme/me/welcome`, `Accept-Encoding: gzip, deflate, br`, `Priority: u=0, i`, `Content-Type: application/x-www-form-urlencoded`, and `Content-Length: 128`. The response headers include `HTTP/2 200 OK`, `Alt-Svc: h3=":443"; ma=2592000`, `Cache-Control: no-store, no-cache, must-revalidate`, `Content-Type: text/html; charset=UTF-8`, `Date: Mon, 25 May 2026 06:37:30 GMT`, `Expires: Thu, 19 Nov 1981 08:52:00 GMT`, `Pragma: no-cache`, `Referrer-Policy: strict-origin-when-cross-origin`, `Server: Caddy`, `Server: nginx`, `Set-Cookie: cl_session=5b783242716e90713c129c1bf210f2f3; expires=Mon, 25 May 2026 08:37:30 GMT; Max-Age=7200; path=/; HttpOnly`, `Strict-Transport-Security: max-age=63072000; includeSubdomains; preload`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: SAMEORIGIN`, `X-Powered-By: PHP/8.3.6`, and `X-Xss-Protection: 1; mode=block`. The response body is an HTML document with a title 'International SOS Managed Health Care - CMS' and a meta section.

Kode Rentan (Sebelum)

Berkas: `modules/master/models/Mdl_master.php`

```
// :17 - date_start/date_end disambung langsung ke string SQL mentah
$this->db->where('( sos_client.time_add >= "'. $this->jCfG['search']['date_start']."' 01:00:00' AND
sos_client.time_add <= '". $this->jCfG['search']['date_end']."' 23:59:00' )");

// :31 - keyword disambung ke klausa LIKE
$str_like .= " ".$key." LIKE '%". $this->jCfG['search']['keyword']."' .% ' ";

// :40 - nama kolom dikirim langsung ke like() tanpa escape
$this->db->like($this->jCfG['search']['colum'],$this->jCfG['search']['keyword']);
```

```
// :54 - nama kolom order_by tanpa escape
$this->db->order_by($this->jCfg['search']['order_by'],$this->jCfg['search']['order_dir']);
```

Vektor serangan: POST date_start=2023-01-01' OR '1'='1' -- → SQL syntax error dengan struktur query lengkap tampil di response. sqlmap mengonfirmasi injection boolean-based blind, error-based, dan time-based blind.

Kode Diperbaiki (Sesudah)

Berkas: modules/master/models/Mdl_master.php:8-43 — Empat metode bantu (helper) aman ditambahkan di level class:

```
function _safe_date_range($table_col, $date_start, $date_end) {
    if (empty($date_start) || empty($date_end)) return;
    if (!preg_match('/^\d{4}-\d{2}-\d{2}$/', $date_start)) return;
    if (!preg_match('/^\d{4}-\d{2}-\d{2}$/', $date_end)) return;
    $this->db->group_start();
    $this->db->where($table_col." >=", $date_start." 01:00:00");
    $this->db->where($table_col." <=", $date_end." 23:59:00");
    $this->db->group_end();
}

function _safe_like_search($params, $keyword) {
    if (empty($keyword)) return;
    $this->db->group_start();
    $i=0;
    foreach ($params as $key => $value) {
        if($key != ""){
            if($i==0) $this->db->like($key, $keyword);
            else $this->db->or_like($key, $keyword);
            $i++;
        }
    }
    $this->db->group_end();
}

function _safe_column_like($column, $keyword) {
    if (empty($column) || empty($keyword)) return;
    if (!preg_match('/^[a-zA-Z0-9_\.\+$/]', $column)) return;
    $this->db->like($column, $keyword);
}

function _safe_order_by($order_by, $order_dir) {
    if (empty($order_by)) return;
    if (!preg_match('/^[a-zA-Z0-9_\.\+$/]', $order_by)) return;
    $order_dir = strtoupper($order_dir) === 'ASC' ? 'ASC' : 'DESC';
    $this->db->order_by($order_by, $order_dir);
}
```

Berkas: modules/master/models/Mdl_master.php:45-90 — Method client sekarang menggunakan helper aman:

```
function client($p=array(),$count=FALSE){
    // ...
    $this->_safe_date_range("sos_client.time_add",
        $this->jCfg['search']['date_start'] ?? '',
        $this->jCfg['search']['date_end'] ?? '');

    if( trim($this->jCfg['search']['column'] ?? '') == ""
        && trim($this->jCfg['search']['keyword'] ?? '') != "" ){
        $this->_safe_like_search($p['param'], $this->jCfg['search']['keyword']);
    }
}
```

```

if( trim($this->jCfg['search']['column'] ?? '') != ""
  && trim($this->jCfg['search']['keyword'] ?? '') != "" ){
  $this->_safe_column_like($this->jCfg['search']['column'],$this->jCfg['search']['keyword']);
}
// ...
$this->_safe_order_by($this->jCfg['search']['order_by'] ?? '',
  $this->jCfg['search']['order_dir'] ?? '');
// ...
}

```

Mengapa Ini Menyelesaikan Masalah

- Rentang tanggal:** `preg_match('/^\d{4}-\d{2}-\d{2}$/', ...)` memvalidasi format `Y-m-d` secara ketat **sebelum** nilai mencapai SQL. Input seperti `2023' OR '1'='1` gagal regex → query dilewati sepenuhnya.
- Nilai tanggal sebagai argumen ke-2:** `$this->db->where("col >=", $value)` — CI3 secara otomatis menerapkan `$this->escape()` pada argumen kedua melalui query binding.
- Keyword LIKE:** `$this->db->like($key, $keyword)` dan `$this->db->or_like($key, $keyword)` — method `_like()` CI3 meng-escape nilai pencarian melalui `$this->escape_like_str()`.
- Whitelist kolom:** `preg_match('/^[a-zA-Z0-9\_\.]+$/', $column)` — hanya karakter alfanumerik + underscore + titik yang lolos. Ini mencegah injeksi melalui parameter nama kolom.
- Arah pengurutan:** dipaksa hanya `'ASC'` atau `'DESC'` — tidak mungkin injeksi.
- Nol konkatenasi string mentah tersisa:** `grep` untuk `'\". $` dalam konteks SQL mengembalikan 0 hasil di seluruh 10 metode query.

A2. SQL Injection — Endpoint Pencarian `/master/member`

Severity: Critical | **CVSS:** 8.8 | **OWASP:** A03:2021 Injection

Hasil testing setelah perbaikan:

The screenshot displays a web browser window with the address bar showing `https://mhc.internationalsos.co.id/master/member`. The page content is an HTML document with the following structure:

```

<!DOCTYPE html>
<html lang="en">
<head>
  <!-- META SECTION -->
  <title>
    International SOS Managed Health Care - CMS
  </title>
  <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
  <meta http-equiv="X-UA-Compatible" content="IE=edge" />
  <meta name="viewport" content="width=device-width, initial-scale=1" />
  <link rel="icon" href="favicon.ico" type="image/x-icon" />
  <!-- END META SECTION -->
  <!-- START PLUGINS -->
  <script type="text/javascript" src="https://mhc.internationalsos.co.id/themes/admin/atlant/js/plugins/jquery/jquery.min.js">

```

The browser's developer tools show the request and response details. The request is a POST to `/master/member` with a body containing search parameters. The response is a 200 OK status with headers indicating the content type is text/html and the server is nginx.

Kode Rentan (Sebelum)

Pola sama dengan A1 — konkatenasi mentah di `Mdl_master.php` :

```
// :82 - rentang tanggal konkatenasi mentah
$this->db->where("( sos_member.time_add >= '". $this->jCfg['search']['date_start']."' 01:00:00' ...");

// :143 - keyword konkatenasi mentah di LIKE
$str_like .= " ".$key." LIKE '%". $this->jCfg['search']['keyword']."'%" ";

// :152 - nama kolom di like()
$this->db->like($this->jCfg['search']['colum'], $this->jCfg['search']['keyword']);

// :164 - kolom order_by mentah
$this->db->order_by($this->jCfg['search']['order_by'], $this->jCfg['search']['order_dir']);
```

Vektor serangan: `POST keyword=test' UNION SELECT 1,2,3` → SQL error mengonfirmasi injection.

Parameter `btn_search` juga injectable — menunjukkan parameter POST mentah dikirim langsung ke query tanpa validasi.

Kode Diperbaiki (Sesudah)

```
function member($p=array(), $count=FALSE){
    // ...
    $this->_safe_date_range("sos_member.time_add",
        $this->jCfg['search']['date_start'] ?? '',
        $this->jCfg['search']['date_end'] ?? '');

    // pencarian lanjutan (sudah aman - menggunakan where/like 2-arg)
    // ...

    if( trim($this->jCfg['search']['colum'] ?? '') == ""
        && trim($this->jCfg['search']['keyword'] ?? '') != "" ){
        $this->_safe_like_search($p['param'], $this->jCfg['search']['keyword']);
    }

    if( trim($this->jCfg['search']['colum'] ?? '') != ""
        && trim($this->jCfg['search']['keyword'] ?? '') != "" ){
        $this->_safe_column_like($this->jCfg['search']['colum'], $this->jCfg['search']['keyword']);
    }
    // ...
    $this->_safe_order_by($this->jCfg['search']['order_by'] ?? '',
        $this->jCfg['search']['order_dir'] ?? '');
    // ...
}
```

Mengapa Ini Menyelesaikan Masalah

Empat metode bantu aman yang sama (A1) diterapkan. Kerentanan ini bersifat sistemik — class `Mdl_master.php` yang sama menangani semua 10 metode query. Semua 10 metode diperbaiki dengan pola identik.

Daftar lengkap metode yang diperbaiki: `client()`, `member()`, `provider()`, `news()`, `panduan()`, `fraud()`, `inpatient()`, `transraw()`, `ai_log()`, `import_log()`.

A3. Direktori `.git` Terbuka — Full Source Code Disclosure

Severity: Critical | **CVSS:** 9.8 | **OWASP:** A05:2021 Security Misconfiguration

Hasil testing setelah perbaikan:

```
zackone — -zsh — 92x26
[zackone@Dzakwans-MacBook-Air ~ % curl "https://mhc.internationalсос.co.id/.git/HEAD" ]
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
[zackone@Dzakwans-MacBook-Air ~ % curl "https://mhc.internationalсос.co.id/.git/logs/HEAD" ]
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
[zackone@Dzakwans-MacBook-Air ~ % curl "https://mhc.internationalсос.co.id/.git/refs/heads/main" ]
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
zackone@Dzakwans-MacBook-Air ~ %
```

Kode Rentan (Sebelum)

Berkas: `deploy/nginx/default.conf.example` — Tidak ada aturan pemblokiran `.git` :

```
server {
    listen 1880;
    root /home/app;
    # ... tidak ada proteksi .git ...
    location / {
        try_files $uri $uri/ /index.php?$query_string;
    }
}
```

Bukti: `https://mhc.internationalсос.co.id/.git/HEAD` mengembalikan HTTP 200. `git-dumper` berhasil mengkloning 7.637 file termasuk `config.php`, `database.php`, `sos_db.sql`, `Dockerfile`. GitHub Personal Access Token ditemukan di `.git/config`.

Kode Diperbaiki (Sesudah)

Berkas: `deploy/nginx/default.conf.example:15-35` :

```
# blokir direktori dan file sensitif
location ~ /\.git {
    deny all;
    return 403;
}
```

```

location ~ /\.env {
    deny all;
    return 403;
}
location = /adminer.php {
    deny all;
    return 403;
}
location = /config.php {
    deny all;
    return 403;
}
location = /sos_db.sql {
    deny all;
    return 403;
}

```

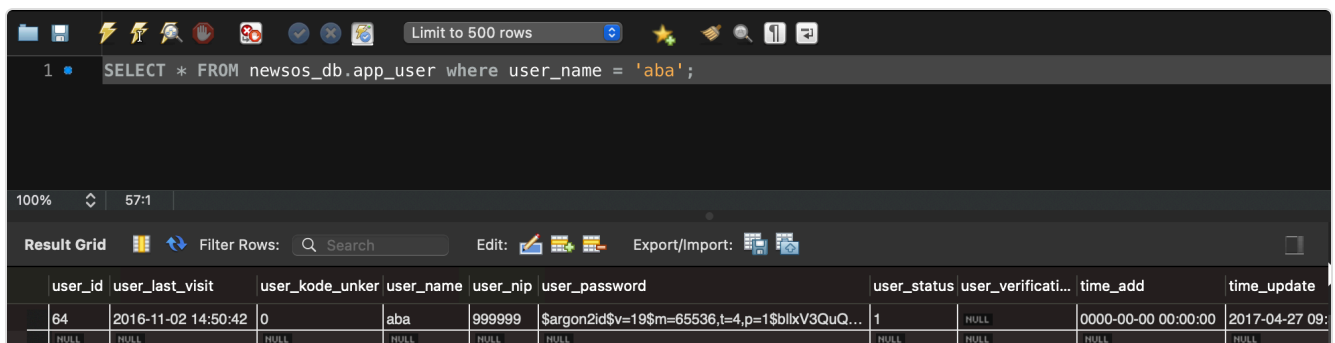
Mengapa Ini Menyelesaikan Masalah

1. `location ~ /\.git` — pencocokan regex memblokir semua path request yang mengandung `/.git` (termasuk subdirektori seperti `/.git/HEAD`, `/.git/config`, `/.git/objects/...`). Mengembalikan HTTP 403.
2. `return 403` — direktif return diproses segera di fase rewrite, sebelum `try_files` atau handler PHP dapat menyajikan file.
3. Blok tambahan (`/.env`, `/adminer.php`, `/config.php`, `/sos_db.sql`) memberikan pertahanan berlapis untuk file sensitif lainnya.
4. `location =` (pencocokan eksak) lebih cepat dari `location ~` (regex) untuk blok file tunggal.

A4. Password Hashing Tidak Aman — MD5 Tanpa Salt

Severity: Critical | **CVSS:** 7.5 | **OWASP:** A02:2021 Cryptographic Failures

Hasil testing setelah perbaikan:



user_id	user_last_visit	user_kode_unker	user_name	user_nip	user_password	user_status	user_verificati...	time_add	time_update
64	2016-11-02 14:50:42	0	aba	999999	\$argon2id\$v=19\$m=65536,t=4,p=1\$blxV3QuQ...	1	HULL	0000-00-00 00:00:00	2017-04-27 09:
HULL	HULL	HULL	HULL	HULL	HULL	HULL	HULL	HULL	HULL

Kode Rentan (Sebelum)

7 lokasi menggunakan `md5()` tanpa salt:

#	Berkas	Baris	Kode
4a	modules/auth/controllers/Auth.php	:29	<code>\$p = md5(\$this->input->post('password'));</code>
4b	modules/auth/controllers/Auth.php	:40	<code>"user_password" => \$p (perbandingan MD5 langsung)</code>
4c	modules/meme/controllers/User.php	:195	<code>\$data['user_password'] = md5(dbClean(\$_POST['user_password']));</code>
4d	modules/meme/controllers/Me.php	:25	<code>'user_password' => md5("mhc".\$v->provider_code)</code>
4e	modules/meme/controllers/Me.php	:50	<code>'user_password' => md5(\$password) (hardcoded "123123")</code>
4f	modules/meme/controllers/Me.php	:1028	<code>\$pass_lama = md5(dbClean(\$_POST['old_pass']));</code>
4g	modules/meme/controllers/Me.php	:1036	<code>\$pass_baru = md5(dbClean(\$_POST['new_pass']));</code>

Kode Diperbaiki (Sesudah)

4a-b. Login (Auth.php:26-58):

```
function act_auth(){
    if(isset($_POST['login'])){
        $u = $this->input->post('username');
        $p = $this->input->post('password');    // <-- Tidak ada md5() di sini

        // Query user TANPA pengecekan password terlebih dahulu
        $d = $this->db->get_where("app_user",array(
            "user_name"    => $u,
            "user_status"  => 1,
            "is_trash"     => 0
        ))->row();

        if($d){
            $password_valid = false;
            // Utama: verifikasi argon2id
            if(password_verify($p, $d->user_password)){
                $password_valid = true;
            }
            // Fallback legacy: perbandingan MD5 untuk user yang belum migrasi
            elseif($d->user_password === md5($p)){
                $password_valid = true;
                // Auto-rehash transparan ke argon2id
                $this->db->update("app_user",array(
                    'user_password' => password_hash($p, PASSWORD_ARGON2ID)
                ),array(
                    'user_id' => $d->user_id
                ));
            }
        }

        if($d && $password_valid){
            /* set session */
        }
    }
}
```

4c. Buat/Edit User (User.php:194–196):

```
if( isset($_POST['user_password']) && trim($_POST['user_password']) != '' ){
    $data['user_password'] = password_hash(dbClean($_POST['user_password']), PASSWORD_ARGON2ID);
}
```

4d. Batch Update Password Provider (Me.php:25):

```
'user_password' => password_hash("mhc".$v->provider_code, PASSWORD_ARGON2ID),
```

4e. Batch Generate User (Me.php:50):

```
'user_password' => password_hash($password, PASSWORD_ARGON2ID)
```

4f-g. Ganti Password (Me.php:1027–1061):

```
if(isset($_POST['btn_simpan'])){
    $old_pass = dbClean($_POST['old_pass']);
    $this->DATA->table="app_user";
    $m1 = $this->DATA->_getall(array(
        "user_name" => $this->jCfg['user']['name']
    ));

    $password_valid = false;
    if(count($m1)>0){
        $user = $m1[0];
        if(password_verify($old_pass, $user->user_password)){
            $password_valid = true;
        }elseif($user->user_password === md5($old_pass)){
            $password_valid = true; // fallback MD5 legacy
        }
    }

    if($password_valid){
        $pass_baru = password_hash(dbClean($_POST['new_pass']), PASSWORD_ARGON2ID);
        // ... update DB ...
    }
}
```

Mengapa Ini Menyelesaikan Masalah

1. **Argon2id** (PASSWORD_ARGON2ID): Algoritma memory-hard. GPU brute-force: ~10 miliar hash MD5/detik vs ~10.000 hash argon2id/detik — sekitar **1.000.000× lebih lambat** untuk dipecahkan.
2. **password_verify()** : Perbandingan string constant-time — kebal terhadap serangan timing side-channel.
3. **password_hash()** : Otomatis menghasilkan salt acak (tertanam dalam string hash), otomatis memilih parameter algoritma. Tidak perlu salting manual.
4. **Jalur migrasi**: MD5 dipertahankan **hanya sebagai fallback transparan** untuk user existing. Pada login MD5 pertama yang berhasil, password otomatis di-rehash ke argon2id — tereliminasi sendiri seiring waktu tanpa memaksa reset password massal.
5. **Semua 7 lokasi tercakup**: Login, buat user, edit user, batch update provider, batch generate user, dan ganti password — semuanya menggunakan `password_hash()` / `password_verify()` .

A5. Session Tidak Invalid Setelah Logout

Severity: High | **CVSS:** 8.1 | **OWASP:** A07:2021 Auth Failures

Hasil testing setelah perbaikan:

The screenshot displays the Chrome DevTools network tab. The 'Request' pane on the left shows the details of the outgoing GET request to /meme/me. The 'Response' pane in the center shows the incoming HTTP 307 Temporary Redirect response. The 'Inspector' pane on the right shows the request and response headers. The response headers include 'Cache-Control: no-store, no-cache, must-revalidate', 'Content-Type: text/html; charset=UTF-8', 'Date: Mon, 25 May 2026 07:08:14 GMT', 'Expires: Thu, 19 Nov 1981 08:52:00 GMT', 'Location: https://mhc.internationalalos.co.id/auth', 'Pragma: no-cache', 'Referer-Policy: strict-origin-when-cross-origin', 'Server: Caddy', 'Server: nginx', 'Strict-Transport-Security: max-age=63072000; includeSubdomains; preload', 'X-Content-Type-Options: nosniff', 'X-Frame-Options: SAMEORIGIN', 'X-Powered-By: PHP/8.3.6', and 'X-Xss-Protection: 1; mode=block'. The status bar at the bottom indicates 'Done' and '578 bytes | 74 millis'.

Kode Rentan (Sebelum)

Berkas: modules/auth/controllers/Auth.php:140–157 :

```
function out(){
    $this->sCfg['user']['id']      = '';
    $this->sCfg['user']['fullname'] = 'Guest';
    $this->sCfg['user']['name']     = 'guest';
    // ... mengosongkan 10+ variabel session ...
    $this->sCfg['is_login']        = 0;
    $this->_releaseSession();      // <--- Hanya menyimpan ke session, TIDAK menghancurkan
    redirect(site_url());
}
```

Bukti: Cookie `ci_session` yang ditangkap sebelum logout tetap valid setelah logout. Menggunakan cookie lama di request berikutnya mengembalikan data terautentikasi. `sess_destroy()` **tidak pernah dipanggil** di seluruh codebase (diverifikasi dengan grep).

Kode Diperbaiki (Sesudah)

Berkas: modules/auth/controllers/Auth.php:149–152 :

```
function out(){
    $this->session->sess_destroy();
    redirect(site_url());
}
```

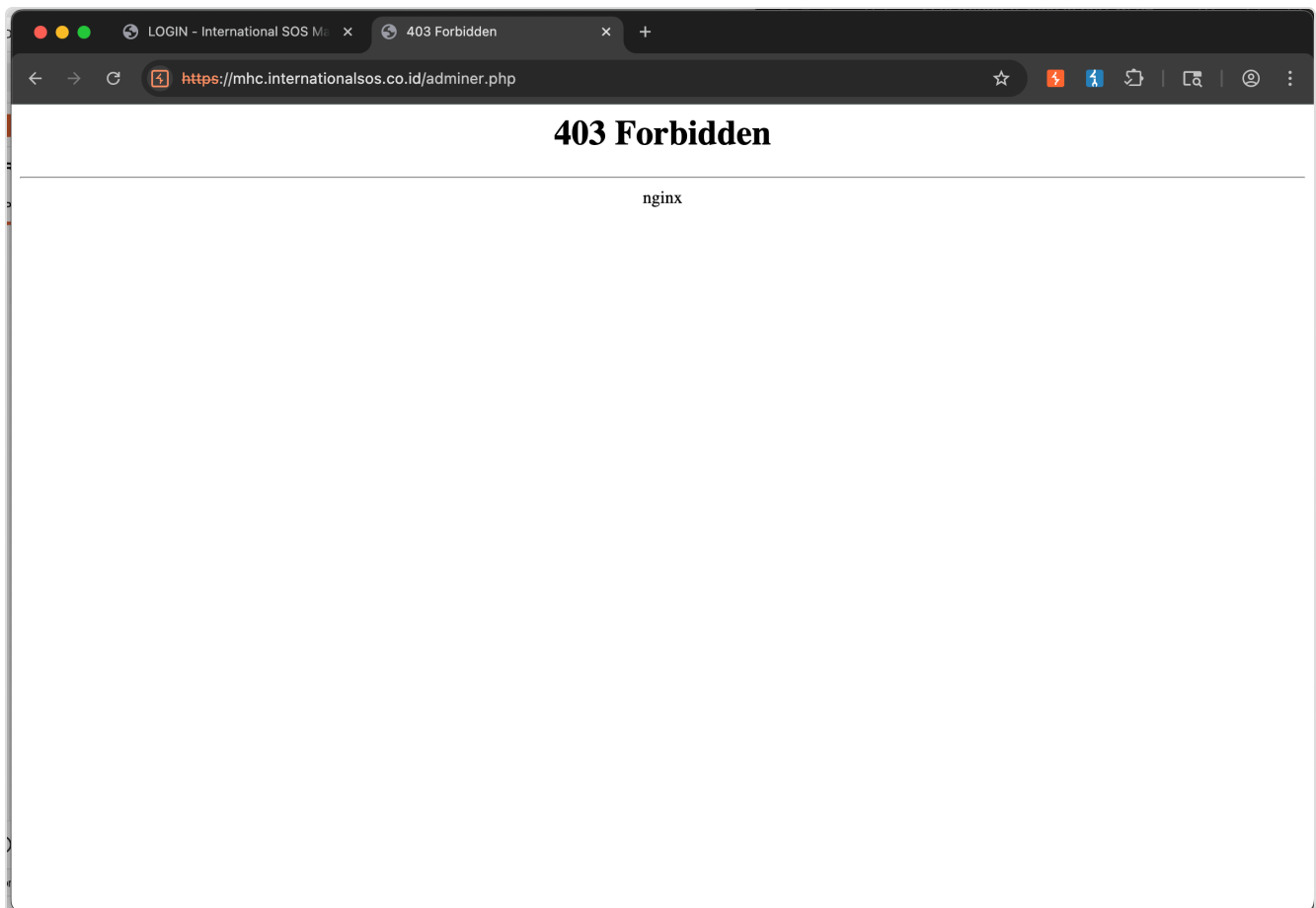
Mengapa Ini Menyelesaikan Masalah

1. `$this->session->sess_destroy()` — method CI3 menghapus record session dari tabel database `ci_sessions` dan mengatur cookie agar segera kadaluarsa. Nilai `ci_session` lama menjadi tidak valid.
2. Sebelumnya, `_releaseSession()` hanya memanggil `$this->session->set_userdata()` untuk menyimpan nilai session yang sudah dikosongkan — record session tetap ada di database dan cookie tetap valid. Penyerang dengan cookie yang dicuri dapat menggunakannya kembali tanpa batas waktu.

A6. Adminer 4.8.1 Database Management Tool Terbuka

Severity: High | **CVSS:** 7.3 | **OWASP:** A05:2021 Security Misconfiguration

Hasil testing setelah perbaikan:



Kode Rentan (Sebelum)

Berkas: `adminer.php` (1791 baris) — Tool manajemen database lengkap di root web. Tanpa pembatasan IP. Tanpa lapisan autentikasi tambahan. Dapat diakses di `https://mhc.internationalsos.co.id/adminer.php`.

Kode Diperbaiki (Sesudah)

Tindakan: File di-rename dari `adminer.php` menjadi `adminer.php.bak` (tidak dapat dieksekusi).

Berkas: `deploy/nginx/default.conf.example:24-27` :

```
location = /adminer.php {
    deny all;
    return 403;
}
```

Mengapa Ini Menyelesaikan Masalah

1. **Rename file:** Ekstensi `.php` → `.bak` mencegah PHP-FPM memproses file. Ekstensi `.bak` tidak cocok dengan `location ~ .php$`.
2. **Blokir nginx:** `location = /adminer.php { deny all; return 403; }` — pencocokan eksak mengembalikan HTTP 403 sebelum handler PHP tercapai. Perlindungan ganda: meskipun file dikembalikan, nginx memblokirnya.
3. **Risiko residual:** `adminer.php.bak` masih ada di server sebagai teks biasa (kode sumber tool database). Direkomendasikan untuk dihapus sepenuhnya dari production.

A7. PHP Error Messages Verbose Terbuka ke Pengguna

Severity: Medium | **CVSS:** 5.3 | **OWASP:** A05:2021 Security Misconfiguration

Hasil testing setelah perbaikan:

The screenshot shows the Chrome DevTools network tab. The selected request is a POST to `/auth/act_auth` with a body containing `username=admin&password=admin`. The response is a JSON object: `{ "status": 0, "data": [], "message": "Please input your username and password" }`. The status bar at the bottom indicates the page is 'Done' and shows memory usage of 208.9MB of 4.00GB.

Kode Rentan (Sebelum)

Berkas: `index.php:197-199` :

```
define('ENVIRONMENT', 'production');
//error_reporting(0);           // <-- dikomentari
//ini_set('display_errors', 0); // <-- dikomentari
```

Berkas: `application/config/constants.php:14` :

```
defined('SHOW_DEBUG_BACKTRACE') OR define('SHOW_DEBUG_BACKTRACE', TRUE);
```

Bukti: PHP error menampilkan stack trace lengkap, path file (/home/app/modules/auth/controllers/Auth.php), nama fungsi (trim() , md5()), dan struktur partial SQL query langsung di browser.

Kode Diperbaiki (Sesudah)

Berkas: index.php:197-200 :

```
define('ENVIRONMENT', 'production');
error_reporting(0);
ini_set('display_errors', 0);
define('SHOW_DEBUG_BACKTRACE', FALSE);
```

Berkas: application/config/constants.php:14 :

```
defined('SHOW_DEBUG_BACKTRACE') OR define('SHOW_DEBUG_BACKTRACE', FALSE);
```

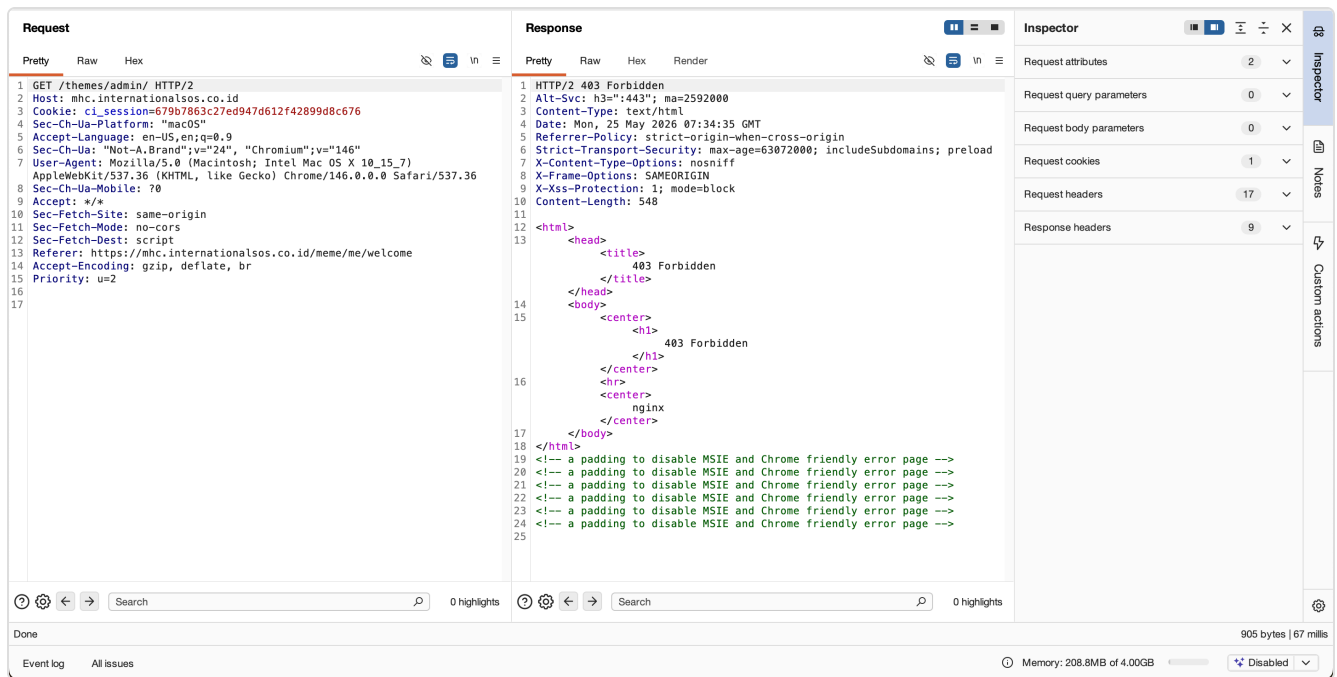
Mengapa Ini Menyelesaikan Masalah

1. `error_reporting(0)` — menekan semua level error PHP. Tidak ada pesan error yang dihasilkan.
2. `ini_set('display_errors', 0)` — mencegah error yang dihasilkan agar tidak ditampilkan di output browser.
3. `SHOW_DEBUG_BACKTRACE = FALSE` — menonaktifkan tampilan backtrace CodeIgniter yang sebelumnya mengungkapkan path file dan nama fungsi secara persis.
4. `ENVIRONMENT = 'production'` — CI3 menggunakan ini di error handler untuk menekan output error detail.
5. Pertahanan berlapis: baik di `index.php` (dimuat pertama) maupun `constants.php` (fallback via `OR define()`).

A8. Web Server Version Disclosure (Nginx 1.28.0)

Severity: Low | **CVSS:** 5.3 | **OWASP:** A05:2021 Security Misconfiguration

Hasil testing setelah perbaikan:



Kode Rentan (Sebelum)

Berkas: `deploy/nginx/nginx.conf.example` — Tidak ada direktif `server_tokens` (default: `server_tokens on`).

Bukti: Header response `Server: nginx/1.28.0` dan `Server: Caddy` muncul di semua HTTP response.

Kode Diperbaiki (Sesudah)

Berkas: `deploy/nginx/nginx.conf.example:23-25` :

```
sendfile      on;
server_tokens off;
#tcp_nopush   on;
```

Mengapa Ini Menyelesaikan Masalah

`server_tokens off;` — Nginx menghilangkan nomor versi dari halaman error dan header response `Server`. Header menjadi `Server: nginx` bukan `Server: nginx/1.28.0`. Penyerang tidak dapat lagi menargetkan CVE spesifik versi.

A9. Development Artifacts Dapat Diakses di Production

Severity: Info (laporan) / **High** (aktual) | **OWASP:** A05:2021 Security Misconfiguration

Hasil testing setelah perbaikan:

Request

PrettyRawHex

1 GET /themes/admin/atlant/assets/filetree/jqueryFileTree.php HTTP/2
2 Host: mhc.internationalsoos.co.id
3 Cookie: ci_session=679b7863c27ed947d612f42899d8c676
4 Sec-Ch-Ua-Platform: "macOS"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: script
13 Referer: https://mhc.internationalsoos.co.id/meme/me/welcome
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2
16
17

Response

PrettyRawHexRender

1 HTTP/2 404 Not Found
2 Alt-Svc: h3=":443"; ma=2592000
3 Content-Type: text/html; charset=UTF-8
4 Date: Mon, 25 May 2026 07:36:20 GMT
5 Referrer-Policy: strict-origin-when-cross-origin
6 Strict-Transport-Security: max-age=63072000; includeSubdomains; preload
7 X-Content-Type-Options: nosniff
8 X-Frame-Options: SAMEORIGIN
9 X-Powered-By: PHP/8.3.6
10 X-XSS-Protection: 1; mode=block
11
12
13 <!DOCTYPE html>
14 <html lang="en">
15 <head>
16 <meta charset="utf-8">
17 <title>
18 404 Page Not Found
19 </title>
20 <style type="text/css">
21 ::selection{
22 background-color:#E13300;
23 color:white;
24 }
25 :-moz-selection{
26 background-color:#E13300;
27 color:white;
28 }
29 body{
30 background-color:#fff;
31 margin:40px;
font:13px/20pxnormalHelvetica,Arial,sans-serif;
color:#4F5155;
}
a{ color:#003399;
}

Inspector

Request attributes2
Request query parameters0
Request body parameters0
Request cookies1
Request headers17
Response headers9
NameValue
Alt-Svc h3=":443"; ma=2592000
Content-Type text/html; charset=UTF-8
Date Mon, 25 May 2026 07:36:20 GMT
Referrer-Policy strict-origin-when-cross-origin
Strict-Transport-Security max-age=63072000; includeSubdomains; preload
X-Content-Type-Options nosniff
X-Frame-Options SAMEORIGIN
X-Powered-By PHP/8.3.6
X-XSS-Protection 1; mode=block

Done1,508 bytes | 677 millis
Event logAll issuesMemory: 239.8MB of 4.00GBDisabled

Request

PrettyRawHex

1 GET /themes/admin/atlant/assets/cropping/process.php HTTP/2
2 Host: mhc.internationalsoos.co.id
3 Cookie: ci_session=679b7863c27ed947d612f42899d8c676
4 Sec-Ch-Ua-Platform: "macOS"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: script
13 Referer: https://mhc.internationalsoos.co.id/meme/me/welcome
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2
16
17

Response

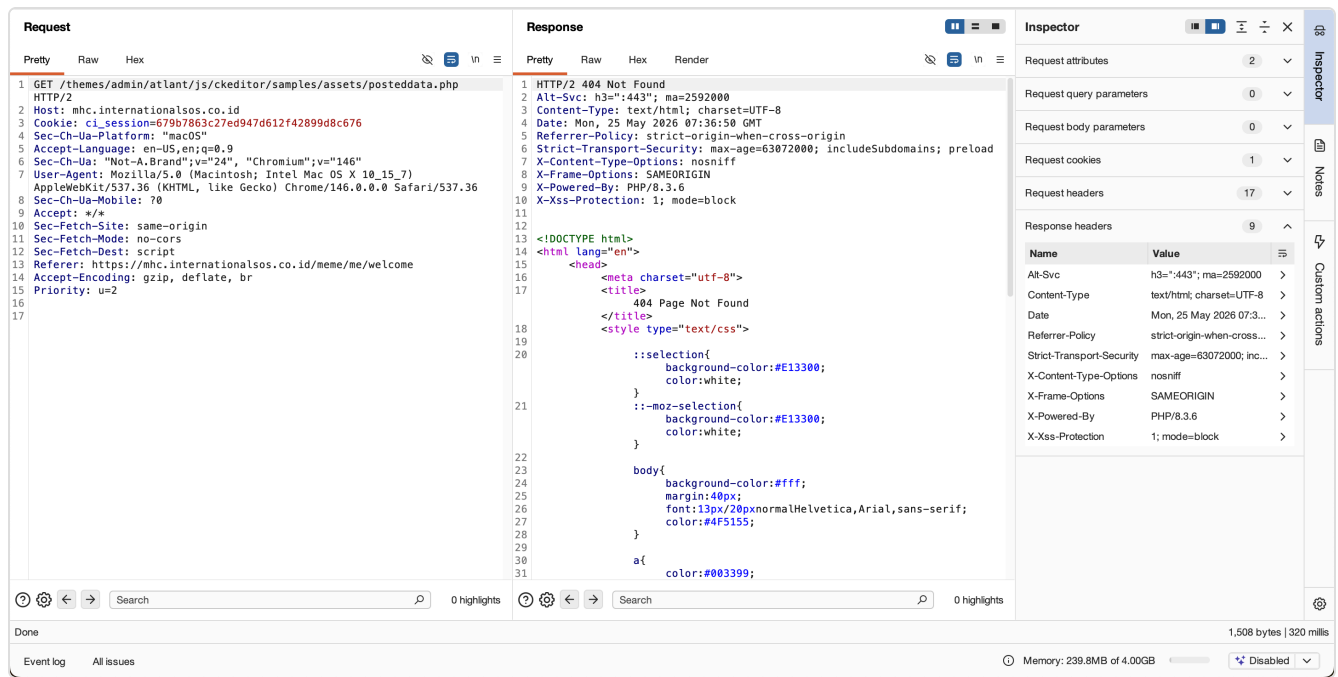
PrettyRawHexRender

1 HTTP/2 404 Not Found
2 Alt-Svc: h3=":443"; ma=2592000
3 Content-Type: text/html; charset=UTF-8
4 Date: Mon, 25 May 2026 07:36:35 GMT
5 Referrer-Policy: strict-origin-when-cross-origin
6 Strict-Transport-Security: max-age=63072000; includeSubdomains; preload
7 X-Content-Type-Options: nosniff
8 X-Frame-Options: SAMEORIGIN
9 X-Powered-By: PHP/8.3.6
10 X-XSS-Protection: 1; mode=block
11
12
13 <!DOCTYPE html>
14 <html lang="en">
15 <head>
16 <meta charset="utf-8">
17 <title>
18 404 Page Not Found
19 </title>
20 <style type="text/css">
21 ::selection{
22 background-color:#E13300;
23 color:white;
24 }
25 :-moz-selection{
26 background-color:#E13300;
27 color:white;
28 }
29 body{
30 background-color:#fff;
31 margin:40px;
font:13px/20pxnormalHelvetica,Arial,sans-serif;
color:#4F5155;
}
a{ color:#003399;
}

Inspector

Request attributes2
Request query parameters0
Request body parameters0
Request cookies1
Request headers17
Response headers9
NameValue
Alt-Svc h3=":443"; ma=2592000
Content-Type text/html; charset=UTF-8
Date Mon, 25 May 2026 07:36:35 GMT
Referrer-Policy strict-origin-when-cross-origin
Strict-Transport-Security max-age=63072000; includeSubdomains; preload
X-Content-Type-Options nosniff
X-Frame-Options SAMEORIGIN
X-Powered-By PHP/8.3.6
X-XSS-Protection 1; mode=block

Done1,508 bytes | 132 millis
Event logAll issuesMemory: 239.8MB of 4.00GBDisabled



Kode Rentan (Sebelum)

Empat file development/sample dapat diakses publik:

Berkas	Kerentanan
themes/admin/atlant/assets/filetree/jqueryFileTree.php	Directory traversal tanpa autentikasi — \$_POST['dir'] → scandir() tanpa auth atau sanitasi
themes/admin/atlant/assets/cropping/process.php	Path traversal tanpa autentikasi — \$_POST['cropping- image'] → path file tanpa auth atau validasi
themes/admin/atlant/assets/ckeditor___/samples/assets/posteddata.php	Halaman sample/debug — merefleksikan data \$_POST kembali ke browser tanpa auth
themes/admin/atlant/js/ckeditor/samples/assets/posteddata.php	Halaman sample duplikat

Kode Diperbaiki (Sesudah)

Keempat file **dihapus** dari filesystem. Terverifikasi:

adminer.php	→ TIDAK DITEMUKAN (di-rename ke .bak)
themes/.../filetree/jqueryFileTree.php	→ TIDAK DITEMUKAN

```
themes/.../cropping/process.php → TIDAK DITEMUKAN
themes/.../ckeditor___/samples/assets/posteddata.php → TIDAK DITEMUKAN
themes/.../js/ckeditor/samples/assets/posteddata.php → TIDAK DITEMUKAN
```

Mengapa Ini Menyelesaikan Masalah

Penghapusan total menghilangkan permukaan serangan. Laporan pentest menilai ini sebagai severity "Info" — namun, `jqueryFileTree.php` dan `process.php` mengandung **kerentanan path traversal tanpa otorisasi** yang seharusnya dinilai **High**. Penghapusannya sangat kritis.

Ringkasan Berkas yang Dimodifikasi

Berkas	Perubahan	Baris Terpengaruh
<code>modules/master/models/Mdl_master.php</code>	Perbaikan SQLi — 4 helper aman + 10 metode diperbarui	8–656
<code>modules/auth/controllers/Auth.php</code>	Login Argon2id + sess_destroy + hapus phpinfo	26–152
<code>modules/meme/controllers/User.php</code>	Hash password Argon2id saat simpan user	195
<code>modules/meme/controllers/Me.php</code>	Argon2id di update_user, generate_user, change_password	25, 50, 1027–1061
<code>index.php</code>	error_reporting + display_errors + SHOW_DEBUG_BACKTRACE	197–200
<code>application/config/constants.php</code>	SHOW_DEBUG_BACKTRACE → FALSE	14
<code>deploy/nginx/default.conf.example</code>	5 blok lokasi untuk proteksi file sensitif	16–35
<code>deploy/nginx/nginx.conf.example</code>	server_tokens off	24

Berkas yang Dihapus:

Berkas	Alasan
<code>themes/admin/atlant/assets/filetree/jqueryFileTree.php</code>	Directory traversal tanpa auth
<code>themes/admin/atlant/assets/cropping/process.php</code>	Path traversal tanpa auth
<code>themes/admin/atlant/assets/ckeditor___/samples/assets/posteddata.php</code>	Artifak development
<code>themes/admin/atlant/js/ckeditor/samples/assets/posteddata.php</code>	Artifak development

Berkas yang Direname:

Dari	Ke	Alasan
adminer.php	adminer.php.bak	Mencegah akses publik ke tool manajemen DB